

İTÜ

Security in Financial Information Systems

Financial Systems and Information Security

Dr. Şerif Bahtiyar
bahtiyars@itu.edu.tr

1

What is THIS course about ?

This course is to

- provide overview of **security in financial information systems**
 - Financial information systems in general
 - Security issues on financial information systems
 - Cryptographic mechanisms used in financial information systems
- discuss basic principles of threats and attacks
- discuss methods to secure financial information systems

Dr. Şerif Bahtiyar

Financial Systems and Information Security

2

This course is **NOT**!

- Cryptography in details
- Software Security
- Operating Systems
- Application Security
- Privacy
- Network Security
- Computers in general



- **Hacking**

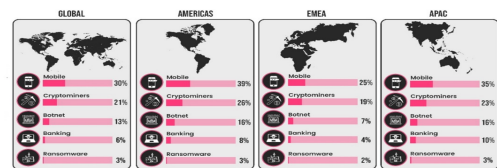
Dr. Şerif Bahtiyar

Financial Systems and Information Security

3

Motivation

CYBER ATTACK CATEGORIES BY REGION



Hackers are constantly finding new targets and refining the tools they use to **break** through cyber defenses on many information systems including financial information systems.

- Sabotage
- Huge data breaches
- Fraud
- Mining cryptocurrencies
- Money laundering
- MORE..

Dr. Şerif Bahtiyar

Financial Systems and Information Security

4

Motivation

John McAfee charged with fraud over cryptocurrency



Businessman John McAfee, creator of the **McAfee anti-virus software**, has been **charged** in the US with conspiracy to commit **fraud** and **money laundering**.

<https://www.bbc.com/news/technology-54900493>

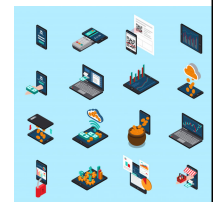
Dr. Şerif Bahtiyar

Financial Systems and Information Security

5

Financial systems

Financial System = Financial Technology = FinTech



Dr. Şerif Bahtiyar

Financial Systems and Information Security

6

Financial systems

A definition for FinTech

Financial Stability Board

Technology-enabled innovation in financial services associated with new business models, applications, processes or products, all of which have a material effect ...'



Dr. Şerif Bahtiyar

Financial Systems and Information Security

7

7

Financial systems

A definition for financial system

A.P. Faure, Financial Systems: An Introduction

A financial system is a set of arrangements/conventions embracing the lending and borrowing of funds by non-financial economic units and intermediation of this function by financial intermediaries in order to facilitate the transfer of funds, to create additional money when required, and to create markets in debt and equity instruments so that the price and allocation of funds are determined efficiently.

Dr. Şerif Bahtiyar

Financial Systems and Information Security

8

8

Financial systems

The definition identifies the following elements:

1. Lenders and borrowers
2. Financial intermediaries
3. Financial instruments (marketable and non-marketable)
4. Creation of money
5. Financial markets
6. Price discovery

Dr. Şerif Bahtiyar

Financial Systems and Information Security

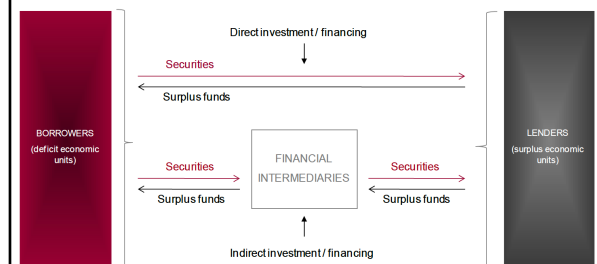
9

9

Financial systems

Simplified financial system

A.P. Faure, Financial Systems: An Introduction



Dr. Şerif Bahtiyar

Financial Systems and Information Security

10

10

Financial systems

Some other entities are:

- Broker and dealers
- Fund managers
- Financial exchanges
- Credit rating agencies
- Financial regulators

Dr. Şerif Bahtiyar

Financial Systems and Information Security

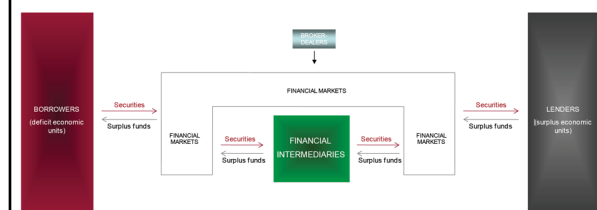
11

11

Financial systems

Financial markets and broker-dealer

A.P. Faure, Financial Systems: An Introduction



Dr. Şerif Bahtiyar

Financial Systems and Information Security

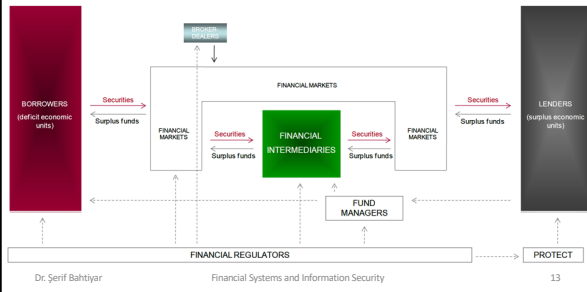
12

12

Financial systems

A more complete model for financial systems

A.P. Tsouros, Financial Systems: An Introduction



Dr. Şerif Bahtiyar

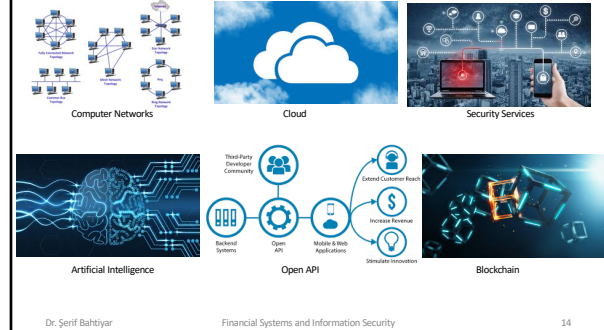
Financial Systems and Information Security

13

13

Financial systems

Some FinTech technologies



Dr. Şerif Bahtiyar

Financial Systems and Information Security

14

14

What is security in real world?

Protection of **assets**



Dr. Şerif Bahtiyar

Financial Systems and Information Security

15

15

What is security in real world?

How?

Prevention: prevent your assets from being **damaged** or **stolen**, such as hire a guard



Dr. Şerif Bahtiyar

Financial Systems and Information Security

16

16

What is security in real world?

How?

Detection: detect **when**, **how**, and by **whom** an asset has been damaged, such as alarms



Dr. Şerif Bahtiyar

Financial Systems and Information Security

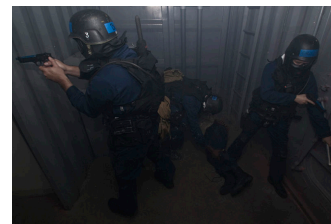
17

17

What is security in real world?

How?

Reaction: **recover** your assets, such as call police or make an insurance claim.



Dr. Şerif Bahtiyar

Financial Systems and Information Security

18

18

What is a computer network?

Computer Network is a **collection** of autonomous computers **interconnected** by a single technology.

Two computers are said to be **interconnected** if they are able to **exchange information**.



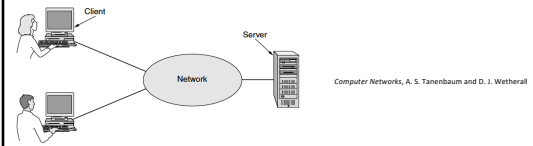
Dr. Şerif Bahtiyar

Financial Systems and Information Security

19

Computer network example - 1

Client - Server Model



Dr. Şerif Bahtiyar

Financial Systems and Information Security

20

Computer network example - 2

Peer to Peer Systems

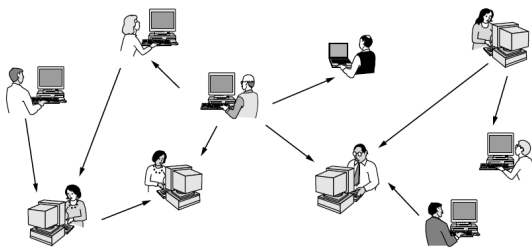


Figure 1-3. In a peer-to-peer system there are no fixed clients and servers.

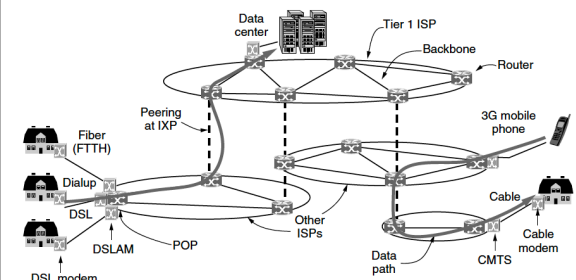
Dr. Şerif Bahtiyar

Computer Networks, A. S. Tanenbaum and D. J. Wetherall
Financial Systems and Information Security

21

Computer network example - 3

Internet



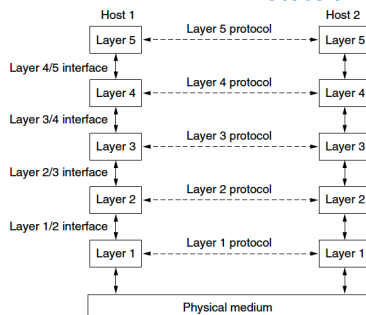
Dr. Şerif Bahtiyar

Computer Networks, A. S. Tanenbaum and D. J. Wetherall
Financial Systems and Information Security

22

Network software

Protocols



Dr. Şerif Bahtiyar

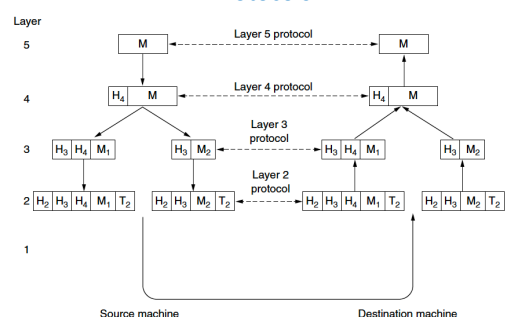
Computer Networks, A. S. Tanenbaum and D. J. Wetherall
Financial Systems and Information Security

23

A set of **layers** and **protocols** is called a **network architecture**.

Network software

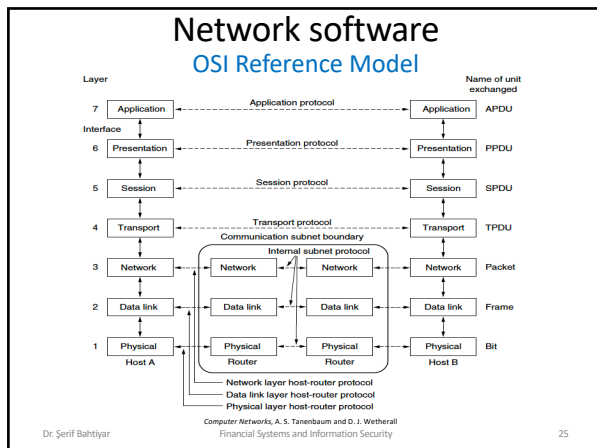
Protocols



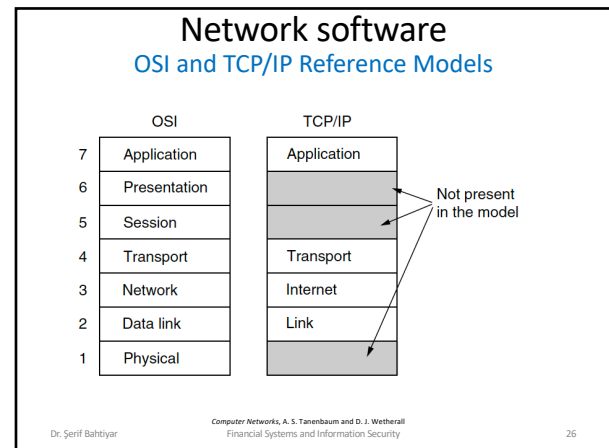
Dr. Şerif Bahtiyar

Computer Networks, A. S. Tanenbaum and D. J. Wetherall
Financial Systems and Information Security

24



25



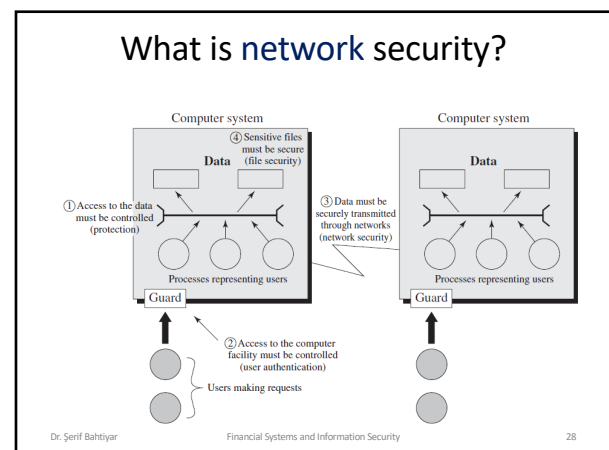
26

What is network security?

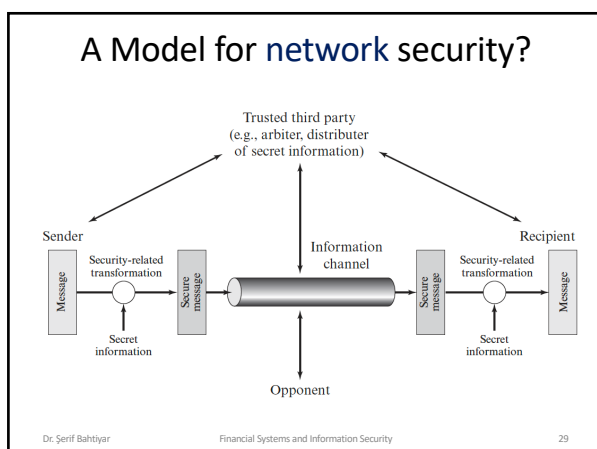
- The field of **network security** consists of measures to deter, prevent, detect, and correct security violations that involve the **transmission of information**.
- The **protection** afforded to an **automated** information system in order to attain the applicable objectives of preventing the **integrity, availability, and confidentiality of information** system resources. (NIST Computer Security Handbook)

Dr. Şerif Bahtiyar
Financial Systems and Information Security

27



28



29

Terminology

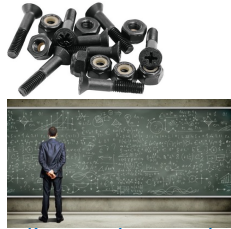
- No single and consistent** terminology in the literature!
- Be careful** not to confuse while reading papers and books

Dr. Şerif Bahtiyar
Financial Systems and Information Security

30

Assets

- Hardware
- Software
- Data
- Communication lines and networks



Dr. Şerif Bahtiyar

Financial Systems and Information Security

31

31

Threat

- A potential for **violating security**.
- A threat is a possible **danger** that might **exploit** a **vulnerability**.

- Potential **consequences**
 - Breach of security
 - Harm



Dr. Şerif Bahtiyar

Financial Systems and Information Security

32

32

Vulnerability

A **flaw** or **weakness** in a system's **design**, **implementation**, or **management** that could be exploited to **violate** the system's **security policy**.

General categories

- Corrupted
- Leaky
- Unavailable



Dr. Şerif Bahtiyar

Financial Systems and Information Security

33

33

Origin of attacks

Attack

A **deliberate attempt** to evade security services and violate the security policy of a system.

Inside attack

Initiated by an entity **inside** the security perimeter.



Outside attack

Initiated from the **outside** perimeter.

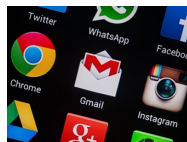
Dr. Şerif Bahtiyar

Financial Systems and Information Security

34

34

Goals of Attacks



- Destroy information
- Steal information

- Blocking to operate properly (denial of service)
- Physical damage
 - **Hi-tech cars are security risk**, warn researchers (<http://www.bbc.com/news/technology-28886463>)



Dr. Şerif Bahtiyar

Financial Systems and Information Security

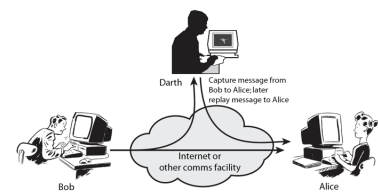
35

35

Types of Attacks-1 (Networks)

Active attack

- Attacker **actively manipulates** the communication
- Masquerade
- Replay
- Denial-of-service



Dr. Şerif Bahtiyar

Financial Systems and Information Security

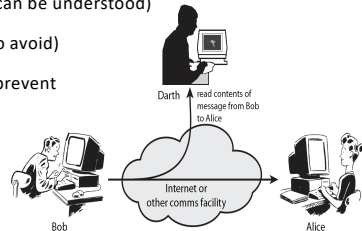
36

36

Types of Attacks-2 (Networks)

Passive attack

- **Interception** of the messages
- Release the content (can be understood)
- Traffic analysis (hard to avoid)
- Hard to detect, try to prevent



Dr. Şerif Bahtiyar

Financial Systems and Information Security

37

37

Countermeasure

An **action**, **device**, **procedure**, or **technique** that **reduces** a **threat**, a **vulnerability**, or an **attack**.

How?

- Eliminating or preventing
- Minimizing the harm
- Discovering and reporting



- **Thus:** **corrective** action can be taken.

- **ADAX (Attack Detection and Countermeasure Assessment)**

Dr. Şerif Bahtiyar

Financial Systems and Information Security

38

38

Objectives of information security

Confidentiality

-It is concealment of information or resources.

- Data confidentiality
- Privacy
- A **loss** of confidentiality is **unauthorized disclosure** of information.



Dr. Şerif Bahtiyar

Financial Systems and Information Security

39

39

Objectives of information security

Integrity

- It prevents improper or unauthorized change of data or system resources.

- Data integrity
- System integrity
- A **loss** of integrity is the **unauthorized modification** or **destruction** of information.



Dr. Şerif Bahtiyar

Financial Systems and Information Security

40

40

Objectives of information security

Availability

- It assures that systems work promptly and service is not denied to authorized users.

- A **loss** of availability is the **disruption of access** to or use of information or an information system.



Confidentiality, Integrity, and Availability are known as the **security requirements triad (CIA triad)**.

Dr. Şerif Bahtiyar

Financial Systems and Information Security

41

41

Additional Goals

Authenticity

The property of being **genuine** and being able to be **verified** and **trusted**; confidence in the validity of transmission, a message, or a message originator.



Dr. Şerif Bahtiyar

Financial Systems and Information Security

42

42

Additional Goals



Accountability

The security goal that generates the requirement for actions of an entity to be **traced** uniquely to that entity.

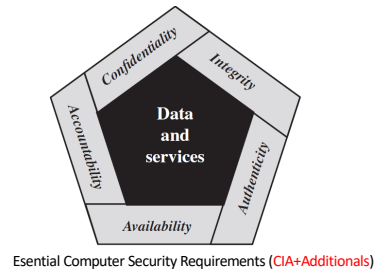


Dr. Şerif Bahtiyar

Financial Systems and Information Security

43

Objectives of information security (revised)



Dr. Şerif Bahtiyar

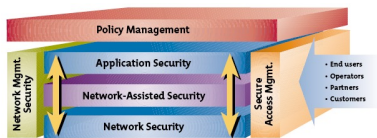
Financial Systems and Information Security

44

Security Architecture

The need for a security architecture

- To **assess** effectively the security needs of an organization
- To evaluate and choose various security products and policies
- **Requirements** should be defined **in a systematic way**.



Dr. Şerif Bahtiyar

Financial Systems and Information Security

45

Security Architecture

ITU-T Recommendation X.800 (Security Architecture for OSI) defines a systematic approach in the **context of networks and communications** that is also applied to **computer security**.

The OSI (*Open Systems Interconnections*) security architecture focuses on

- security attacks,
- mechanisms, and
- services

Dr. Şerif Bahtiyar

Financial Systems and Information Security

46

Security Service



A service **enhances** the **security** of the data processing systems and the information transfers of an organization.

Dr. Şerif Bahtiyar

Financial Systems and Information Security

47

Security Service

- The services are intended to **counter security attacks**, and they make use of one or more security mechanisms to provide the service.



- Security services **implement security policies** and **are implemented by security mechanisms**.

Dr. Şerif Bahtiyar

Financial Systems and Information Security

48

Security Mechanism -X.800

- A mechanism that is designed to **prevent, detect, or recover from a security attack.**
- Specific security mechanisms
 - Encipherment
 - Digital signature
 - Access control
 - Data integrity
 - Authentication exchange
 - Traffic padding
 - Routing Control

Dr. Şerif Bahtiyar

Financial Systems and Information Security

49

49

Fundamental Security Design Principles

- Economy of mechanisms
- Fail-safe defaults
- Complete mediation
- Open design
- Separation of privilege and least privilege
- Least common mechanism
- Psychological acceptability
- Isolation and Encapsulation
- Modularity and Layering
- Least astonishment

Dr. Şerif Bahtiyar

Financial Systems and Information Security

50

50

Attack Surfaces and Attack Trees

Attack Surface

It consists of reachable and exploitable vulnerabilities in a system.

(An attack surface **analysis** is a useful technique for **assessing the scale and severity of threats** to a system.)

Categories of Attack Surfaces

- **Network**
- Software
- Human

Attack Tree

It is a **branching, hierarchical data structure** that represents a set of potential techniques for exploiting security vulnerabilities.

Dr. Şerif Bahtiyar

Financial Systems and Information Security

51

51

Summary

- About this course
- Computer networks
- Reference models
- What is network security?
- Objective of network security
- Terminology
- Attacks, services, mechanisms
- Fundamental Security Design Principles
- Attack Surfaces and Attack Trees

Dr. Şerif Bahtiyar

Financial Systems and Information Security

52

52

Questions?

Dr. Şerif Bahtiyar

Financial Systems and Information Security

53

53